

SOC / ENTERPRISE PENTEST HOMELAB

SOC Homelab

Master Documentation

Samengevoegde, gededuplicateerde referentie voor het volledige SOC Homelab project — architectuur, systemen, beslissingen, guides, troubleshooting-historie, tijdlijn en attack scope-voorstellen.

Auteur: Joost Hebly · **Samengesteld:** 13 juli 2026 · **Bron:** git repo /Homelab (docs/) + live labverificatie

Betrouwbaarheidslegenda:  geverifieerd deze sessie / harde evidentie ·  niet opnieuw geverifieerd of open actiepunt ·  gepland / nog niet gebouwd.

Table of contents

1. Project overview & purpose

Origin: from "Fortress Bazzite" to this lab
AI collaboration model

2. Architecture & network design

Network map
IP address table (verified 2026-07-13)
Virtual networks (libvirt, verified via ``virsh net-list --all``)
Physical host
Traffic mirroring (``soc-mirror.service``)
DNS and DHCP
Security principles baked into the network
Planned network improvements (from the original Fortress Bazzite plan, not yet built)

3. Systems in detail

3.1 Bazzite Linux host & virtualization
3.2 OPNsense (firewall/gateway)
3.3 DC01 — Active Directory Domain Controller
3.4 WIN11-01 — Windows 11 workstation
3.5 ubuntu-server-01 — Linux server, active Red Team target
3.6 Security Onion — SOC platform
3.7 Kali Linux — Red Team workstation
3.8 Metasploitable2 — vulnerable training target

4. Architecture & security decisions

Why these technologies were chosen
AI implementation & rules (binding on any AI assistant working on this project)
Why two assistants, and why split this way
Role definition (from ``CLAUDE.md``)
Source of truth for AI behavior
Allowed AI actions
Restricted — AI must never
Credential handling
Infrastructure change procedure
Troubleshooting method (mandated order)
AI project behavior — general expectations
What "read-only investigation" covers in practice
Final principle

Core security principles (from `docs/decisions/security\_decisions.md` and `SECURITY.md`)

Incident response phases (from `SECURITY.md`, operationalized in the runbook — [§6.2](#62-incident-response-runbook))

5. Operational guides

5.1 Starting/stopping the lab

5.2 Connecting to systems

5.3 Security Onion / Kibana / Fleet in the browser

5.4 Network ports & firewall hostgroups reference

5.5 Desktop launchers

5.6 Quick reference — common operations

6. Detection use cases & incident response

6.1 What this SOC should detect

6.2 Incident response runbook

6.3 Detection validation plan

7. Troubleshooting history

7.1 QEMU guest agent not configured

7.2 virt-manager VM setup issues

7.3 OPNsense network debugging

7.4 Security Onion installation

7.5 DC01 Active Directory setup

7.6 DC01 Fleet health & Sysmon telemetry (2026-07-13)

7.7 The `soc-mirror.sh` libvirtd deadlock (found while building the launchers)

7.8 libvirt/OPNsense DHCP conflict (2026-07-09)

8. Project timeline

9. Asset inventory

Physical host

Virtual machines

Virtual networks

Active Directory identity inventory

Software versions

Desktop launchers (on the Bazzite host)

Access methods (no passwords stored here)

Open verification items

10. Glossary

11. Current project status / what's next

✅ Done (working, tested, documented)

⚠️ Not yet done / open

✗ Planned (from the original Fortress Bazzite design, largely still relevant)

Keeping this document (and the project) current

12. Attack scope proposals (Red Team test plan)

Agreed scope (decided 2026-07-13)

Tier 1 — Reconnaissance & enumeration (lowest risk, good first step)

Tier 2 — Exploitation of intentionally-vulnerable targets (low risk — these boxes exist to be broken)

Tier 3 — Active Directory attack chain (needs a scoping decision first)

Next session checklist (execution, not documentation)

Document index (sources compiled into this file)

1. Project overview & purpose

SOC Homelab (originally named "**Fortress Bazzite**") is Joost Hebly's private cybersecurity training environment. It exists to learn how a real Security Operations Center works by building and operating one — including the real-world problems that come with it (firewalls too strict, clocks that won't sync, agents that won't check in).

Focus areas:

- **Blue Team:** security monitoring, SIEM use (Security Onion/Kibana), incident response, log analysis, network visibility (traffic mirroring), detection engineering.
- **Red Team:** vulnerability testing, exploitation practice, attack simulation, Active Directory security testing.
- Realistic **Active Directory** identity environment and general **network defense**.

The project doubles as a portfolio piece — Joost produces formal deliverables from it (project reports, daily reports, technical documentation, a portfolio document) alongside the working lab itself.

Origin: from "Fortress Bazzite" to this lab

The project began as **Fortress Bazzite**, captured in an early design document (`Fortress_Bazzite_joost-hebly_rapport_network_security_IDS_IPS.docx`, 2026-07-05). That plan described a self-built combination of Suricata (NIDS), Zeek (network telemetry), Wazuh (host monitoring), and a custom dashboard (system health, security and gaming metrics).

In practice, **Security Onion** was chosen as the platform instead. This isn't a change of goal, just a different way to reach it: Security Onion already bundles Suricata and Zeek, and uses Elastic Agent/Fleet for host monitoring — the role Wazuh would have filled. The original detection goals from the Fortress Bazzite document (port scans, brute force, reverse shells, web attacks, etc.) remain the target; see [§6](#).

AI collaboration model

Two assistants are used deliberately for different roles:

- **ChatGPT** — architecture, planning, troubleshooting strategy.
- **Claude Code** — terminal operations, documentation, scripts, implementation.

AI assistants operate under a written access policy (see [§4](#)): read documentation first, never store secrets, explain before changing infrastructure, ask before destructive actions, document every important change.

Golden rule (from the top-level README): No destructive changes without approval. All changes must be documented.

2. Architecture & network design

Network map



Security Onion has **two network interfaces**: one on `pentest-lab` (192.168.50.30, for Fleet/Kibana/SSH/web UI) and one on `monitor-net` (no IP addressing, receives only mirrored traffic — see "Traffic mirroring" below).

IP address table (verified 2026-07-13)

IP	System	virsh VM name	SSH alias	SSH user	Status
192.168.50.1	OPNsense (firewall/gateway)	OPNsense-FW	opnsense	root	✓
192.168.50.10	DC01 (Active Directory, PDC Emulator, domain pentest.lab)	DC01	dc01	Administrator	✓
192.168.50.20	WIN11-01 (Windows 11 workstation, domain-joined as DESKTOP-EFKB8GQ)	WIN11-01	(none — no SSH server)	—	✓
192.168.50.30	Security Onion 3.1.0 standalone (SIEM/IDS/Fleet)	SOC-SecurityOnion	security-onion	socadmin	✓
192.168.50.100	ubuntu-server-01 (Linux server, live OWASP Juice Shop on :3000)	ubuntu-server-01	ubuntu-server	ubuntu (key auth not yet set up)	✓
192.168.50.50	Kali Linux (Red Team workstation)	ATTACK-Kali  <i>leading space in the name — see below</i>	kali	blue1	✓
192.168.50.70	Metasploitable2 (intentionally vulnerable target)	Target-Metasploitable2	(none)	—	✓

 **Known naming bug:** the VM name `ATTACK-Kali` begins with a literal space character in libvirt. This previously caused a real bug in scripts that matched VMs by name (see `soc-mirror.sh` history in [§7](#)). New scripts should either account for the space or, better, match on UUID instead of name.

Conflicting historical IPs (resolved 2026-07-13): Several earlier documents (the English-language `SERVERS.md` , `ACTIVE_DIRECTORY.md` /chat-history archives, and the original `virtualization.md` / `opnsense_setup.md` / `security_onion_setup.md` guides) listed **Security Onion at 192.168.50.20** — `.20` is actually WIN11-01, Security Onion is `.30` . Similarly, the 2026-07-09 daily report's DHCP plan assigned Kali to `.20` and Metasploitable2 to `.50` ; the verified reality is Kali on `.50` and WIN11-01 on `.20` .

A second, previously-undocumented IP error found and fixed this session: `ubuntu-server-01` was documented everywhere as `.40` . Live verification (`virsh domiflist` MAC `52:54:00:0e:0f:65` cross-referenced against the ARP table on `virbr10`) shows its real `pentest-lab` IP is `.100` — nothing has ever answered on `.40` . This explains why the role was never documented: the `ubuntu-server` SSH alias pointed at a dead address the entire time. The alias in `~/.ssh/config` has been corrected. `Target-Metasploitable2` 's IP, previously unverified, is confirmed `.70` (MAC

52:54:00:1b:cf:b3 , found via a ping sweep + ARP lookup; its open-port profile — 21/22/23/25/53/80/111/139/445/512-514/1099/1524/2049/2121/3306/3632/5432/5900/6000/6667/6697/8009/8180/8787 — is the unmistakable stock Metasploitable2 fingerprint).

Virtual networks (libvirt, verified via `virsh net-list --all`)

Network	Status	Purpose
pentest-lab	active	Main network, 192.168.50.0/24, isolated. No libvirt-native DHCP — OPNsense handles this exclusively (see §7 for why).
monitor-net	active	Isolated, no IP addressing, exclusively for traffic mirroring to Security Onion.
default	active	Standard libvirt network, not used by lab VMs.

Physical host

Bazzite Linux — the physical machine running everything.

✓ The following hardware specs were live-verified directly on the host this session (`lscpu` , `lspci` , `free -h`) — they originally came from the Fortress Bazzite design document (2026-07-05) and turned out to be exactly correct:

- CPU: Intel Core i9-11900K (8 cores / 1 socket)
- GPU: NVIDIA GeForce RTX 3090 (GA102)
- RAM: 62 GiB
- WiFi: Intel AX210 (Wi-Fi 6E) — card confirmed present; PCI-passthrough to Kali not reconfirmed this session
- Virtualization: KVM/QEMU/libvirt/virt-manager
- ⚠ Docker/OWASP Juice Shop was not found running on the host itself this session — Juice Shop is confirmed live on `ubuntu-server-01` instead (§3.5); it's possible that was always its actual location and the host-level Docker note was inaccurate

Traffic mirroring (`soc-mirror.service`)

Security Onion sees network traffic from the other lab VMs via an event-driven mirroring mechanism (`scripts/soc-mirror.sh` , triggered by a libvirt qemu hook on every VM start/stop):

1. When a VM on `pentest-lab` starts, its traffic is mirrored to Security Onion's `monitor-net` interface.
2. When Security Onion itself restarts (getting a new network interface), stale mirror rules are automatically cleaned up and recreated.
3. No periodic timer — everything is driven by VM start/stop events. Check status with:

```
scripts/soc-mirror.sh --status
```


A real libvirtd deadlock bug was found and fixed in the hook that drives this — see [§7](#).

DNS and DHCP

- **DHCP:** handled entirely by OPNsense (libvirt's own DHCP for `pentest-lab` was deliberately removed — see [§7](#)).
- **DNS:** DC01 (Active Directory DNS) for the `pentest.lab` domain; OPNsense forwards external queries.
- **⚠️** Exact DHCP ranges and DNS forwarders are not documented in detail. **Attempted this session:** the `opnsense` SSH alias (root, previously documented as passwordless in `docs/PROJECT_STATUS.md`) returned `Permission denied (publickey,password,keyboard-interactive)` — passwordless access to OPNsense is currently broken or was never actually working. Needs either the OPNsense web UI (manual) or SSH key access restored before this can be verified.

Security principles baked into the network

- **Segmentation** — `monitor-net` is fully separated from `pentest-lab` ; only Security Onion sits on both.
- **Least privilege** — Security Onion's firewall hostgroups ensure each system can only reach the ports it actually needs.
- **Monitor first** — from the original Fortress Bazzite design: full visibility before additional blocking or automated response.
- **Documentation required** — every infrastructure change is recorded (`docs/daily/` , `docs/troubleshooting/`).

Planned network improvements (from the original Fortress Bazzite plan, not yet built)

VLAN segmentation · a separate management network · a separate attack network · additional Windows clients · honeypots · more SOC sensors.

3. Systems in detail

3.1 Bazzite Linux host & virtualization

Role: Physical virtualization host running all isolated lab VMs, while also serving as Joost's daily desktop/gaming machine.

Why Bazzite: modern Linux desktop, good hardware support, NVIDIA GPU support, gaming capability, and full access to native Linux virtualization tooling — the same machine covers daily computing, gaming, and lab hosting. Lesson learned: a desktop Linux system can successfully function as a serious home virtualization host when properly configured.

Stack: KVM (kernel virtualization) + QEMU (hardware emulation) + libvirt (management layer) + virt-manager (GUI). Chosen over VMware Workstation / VirtualBox / Proxmox for native Linux integration and to understand the technology directly, at some ergonomics cost.

Storage: VM disks use qcow2 (snapshot support, thin provisioning). One VM image was converted from VMDK: `qemu-img convert -f vmdk -O qcow2 source.vmdk destination.qcow2`.

Networking note: an early VM (Pentest-Kali , actually Debian 12, not real Kali) hit VirtIO incompatibility (initramfs hangup) with an old Metasploitable2 kernel — fixed by switching that VM to i440FX chipset + SATA disk + e1000 NIC. See [§8](#) for full history.

Basic VM lifecycle:

```
virsh list --all
virsh start VMNAME
virsh shutdown VMNAME      # graceful; use --destroy only if truly stuck
virsh domdisplay VMNAME    # SPICE display connection
```

QEMU guest agent: not configured on VMs by default — `virsh qemu-agent-command` fails with `QEMU guest agent is not configured` until the in-guest agent is installed, enabled, and the channel is configured (see [§7](#)).

3.2 OPNsense (firewall/gateway)

Role: Central firewall and network gateway — the security boundary between the outside and the internal 192.168.50.0/24 lab network. Provides firewall, routing, DHCP, DNS forwarding, and network segmentation.

Why OPNsense: open-source, enterprise-style feature set, realistic firewall/routing/DHCP/DNS practice, good learning value for firewall troubleshooting and policy management.

IP: 192.168.50.1 (LAN interface). SSH alias `opnsense`, user `root` (password-only — no key auth set up as of the last check).

History note: first installed 2026-07-07; the first install attempt hung in "live media mode" (never actually installed to the VirtIO disk) and was redone with ZFS. WAN firmware-update/internet

connectivity had a DHCP/gateway problem that took until 2026-07-09 to fully resolve, alongside a separate libvirt-vs-OPNsense DHCP conflict (see [§8](#)).

3.3 DC01 — Active Directory Domain Controller

Role: Primary (and only) Windows Server Domain Controller.

Verified facts (2026-07-13):

- OS: Windows Server 2022 Standard Evaluation
- Domain: `pentest.lab` — DC01 is the domain's **PDC Emulator** (its only DC)
- IP: 192.168.50.10 (static)
- SSH alias `dc01`, user `Administrator` (username best-guess, not fully verified; port confirmed open)
- Timezone: `W. Europe Standard Time` (Amsterdam/CEST), set 2026-07-13 for local-time readability in Event Viewer/file timestamps — the underlying UTC clock remains authoritative for correlation with Security Onion

Documentation gap, now closed (2026-07-13): `ACTIVE_DIRECTORY.md` (the older root-level doc) used to list the domain name as "TO BE DOCUMENTED" and describe the OU/security-group structure as only "planned." Both were wrong: the domain (`pentest.lab`) has existed since 2026-07-10, and **the OU/group structure is already built** — live-verified this session via read-only `dsquery` over the `dc01` SSH alias.

Services: AD Domain Services, DNS, authentication, user/group management, Group Policy (not yet configured in detail — no custom GPOs found).

✓ **Actual OU structure (`dsquery ou` , live 2026-07-13):**

```
DC=pentest,DC=lab
├── OU=Domain Controllers    (DC01)
├── OU=Admins                (1 user: IT Admin 01)
├── OU=AD-Users              (6 users)
├── OU=Workstations          (empty)
├── OU=Servers               (empty)
├── OU=Groups                (2 custom groups)
└── OU=Service-Accounts     (1 user: SQL Service)
```

✓ **Actual accounts (`dsquery user`):** built-in `Administrator` / `Guest` / `krbtgt`, plus role-flavored accounts `soctest`, `Helpdesk 01`, `Employee 01`, `Manager 01`, `HR 01`, `Finance 01` (all in `OU=AD-Users`), `IT Admin 01` (`OU=Admins`), and `SQL Service` (`OU=Service-Accounts`).

✓ **Actual groups (`dsquery group`):** two custom groups exist beyond the AD defaults — `SOC-Analysts` (member: `soctest`) and `Helpdesk` (no members). `Domain Admins` contains only the built-in `Administrator`.

⚠ **Real gaps found (infrastructure state, not documentation errors — left as-is, not silently fixed):**

- `OU=Workstations` and `OU=Servers` are empty. WIN11-01's computer object (`DESKTOP-EFKB8GQ`) is still sitting in the default `CN=Computers` container, never moved.
- `IT Admin 01` lives in `OU=Admins` but holds **no elevated group membership** — it's a plain `Domain Users` account despite the name/placement.
- `Helpdesk 01` exists but the `Helpdesk` group has zero members — never linked.
- `Employee 01` / `Manager 01` / `HR 01` / `Finance 01` are all identical, undifferentiated `Domain Users` accounts — no group-based privilege separation between them yet, which matters for planning any privilege-escalation attack scenario (see [§12](#)).

Monitoring integration (built 2026-07-13): Elastic Agent (build `9.3.3+build202604082258`) enrolled in Security Onion's Fleet; Sysmon `15.21` (schema 4.91) installed with the `SwiftOnSecurity` config (schema 4.50, still compatible). Full story and root causes in [§7](#).

Time sync: uses `pool.ntp.org` . The Windows `vmictimesync` hypervisor-integration service was found fighting with NTP at every boot and is now disabled, with a scheduled task forcing an NTP resync 30s after startup (see [§7](#)).

3.4 WIN11-01 — Windows 11 workstation

IP: 192.168.50.20. No SSH server installed (normal for a Windows 11 client) — not reachable via an SSH alias.

✓ Live-verified 2026-07-13:

- **Domain-joined** to `pentest.lab` as computer object `CN=DESKTOP-EFKB8GQ,CN=Computers,DC=pentest,DC=lab` (confirmed via `dsquery computer` on DC01). The Windows machine name was never customized to `WIN11-01` — that's only the libvirt VM name — and the computer object still sits in the default `Computers` container rather than the (already-created) `OU=Workstations` .
- **Locked-down network surface:** a direct port probe from the hypervisor found only TCP 135 (RPC endpoint mapper) open. 445 (SMB), 3389 (RDP), 5985/5986 (WinRM), and 139 are all closed/filtered — Windows Firewall is blocking inbound management access from the lab network. There is no remote-admin path to this box from the network side; management has to go through the VM console (virt-manager).
- ⚠ **Still open:** *why* this box exists (its intended training purpose — analyst workstation? phishing target? generic domain-client telemetry source?) is a product/scope decision, not a technical fact — see [§12](#) and the open questions in [§11](#).

3.5 ubuntu-server-01 — Linux server, active Red Team target

IP: 192.168.50.100 — **corrected 2026-07-13** (every prior document said `.40` ; nothing has ever answered there — see the conflict note in [§2](#)). SSH alias `ubuntu-server` now points at the right host; user `ubuntu` (best-guess, **not yet confirmed** — the SSH banner confirms `OpenSSH_10.2p1 Ubuntu-2ubuntu3.2` , but key-based login currently fails with `Permission denied (publickey,password)` , so there is no passwordless access to this system yet, unlike `security-onion/kali/dc01`).

✓ **Live-verified 2026-07-13 (unauthenticated — HTTP probe only, no login):** port 3000 serves **OWASP Juice Shop**, confirmed via HTTP response headers and page content. This isn't a leftover from the earlier Fortress Bazzite phase — the container is **live right now**. Functionally this makes ubuntu-server-01 an active, intentionally-vulnerable web-application target (OWASP Top 10 practice), alongside its "general Linux server" role.

3.6 Security Onion — SOC platform

Role: Central Security Operations Center monitoring platform — SIEM, IDS, Network Security Monitoring, log collection, alert investigation, threat detection.

Verified facts (2026-07-13):

- Version: Security Onion 3.1.0, standalone installation
- VM name (virsh): `SOC-SecurityOnion`
- IP: 192.168.50.30 (⚠ several older docs incorrectly list `.20` — see the conflict note in [§2](#))
- SSH alias `security-onion`, user `socadmin` (key auth already working)
- OS-level timezone intentionally left on UTC (`Etc/UTC`) — standard practice since Elasticsearch is UTC-internal regardless; the web UI (Hunt, Kibana) already renders browser-local time (confirmed `+02:00 /CEST`). Aligning the OS-level timezone to `Europe/Amsterdam` for raw SSH-log readability is a low-priority open item, blocked on root access beyond the narrow `so-firewall` -scoped sudo currently granted.

Own firewall (separate from OPNsense): Security Onion has its own internal firewall gating which IPs can reach which of its own ports, based on **hostgroups** (named IP groups) mapped to **portgroups** (named port groups). Membership in one hostgroup does **not** grant access to another hostgroup's ports — this was the root cause of the entire DC01 Fleet outage (see [§7](#)). Full reference: [§5.4](#).

Bundled capabilities: Suricata (network intrusion detection), Zeek (network telemetry/connection logs), Elasticsearch (log storage, UTC-internal), Kibana, Fleet (agent management), Hunt (Security Onion's own search UI, similar to Kibana Discover).

Components delivered by Elastic Agent on endpoints: Beats-equivalent log shipping, Windows Event Log / Sysmon collection, Elastic Defend (endpoint security/EDR, uses its own connection on port 3765 via the `endgame` hostgroup, separate from ordinary log ingest).

3.7 Kali Linux — Red Team workstation

Role: Penetration testing workstation. VM name `ATTACK-KaLi` (leading space — known bug, see [§2](#)). IP 192.168.50.50. SSH alias `kaLi`, user `blue1` (key auth working). Used for vulnerability scanning, exploitation testing, network analysis — authorized testing within this isolated lab only.

Early in the project this VM was actually Debian 12 (named `Pentest-KaLi`) rather than a genuine Kali install; a real Kali deployment is implied by the current asset inventory naming, though the exact re-install point isn't separately documented.

3.8 Metasploitable2 — vulnerable training target

VM name `Target-Metasploitable2` . **IP: 192.168.50.70 — verified 2026-07-13** (the 2026-07-09 DHCP plan had assigned it `.50` , which Kali now occupies; found via a ping sweep + ARP lookup keyed on its libvirt MAC `52:54:00:1b:cf:b3`). Intentionally vulnerable, used for exploitation/detection-testing practice. A direct port probe confirms the classic, unmodified Metasploitable2 port fingerprint (FTP 21, SSH 22, Telnet 23, SMTP 25, DNS 53, HTTP 80, rpcbind 111, NetBIOS 139, SMB 445, rexec/rlogin/rsh 512-514, Java-RMI 1099, ingreslock 1524, NFS 2049, ProFTPD backdoor port 2121, MySQL 3306, distccd 3632, PostgreSQL 5432, VNC 5900, X11 6000, UnrealIRCd 6667/6697, AJP 8009, Tomcat 8180, distccd/other 8787). Does not respond to ACPI shutdown (no `acpid` on that old image) — `lab-stop.sh` always ends up force-stopping it via `virsh destroy` after a 60s timeout; this is expected, not a bug.

4. Architecture & security decisions

Why these technologies were chosen

Decision	Choice	Core reason
Host OS	Bazzite Linux	Already provided modern Linux + NVIDIA support + gaming capability + virtualization tooling on one machine
Virtualization	KVM/QEMU/libvirt/virt-manager	Native Linux virtualization, full control, deeper technical understanding than a turnkey hypervisor
Firewall	OPNsense	Realistic enterprise firewall/routing/DHCP/DNS practice
SOC platform	Security Onion	Complete, realistic SOC platform (SIEM+IDS+NSM) in one bundle, superseding a hand-rolled Suricata/Zeek/Wazuh stack
Identity	Windows Server AD (DC01)	Most enterprise environments run AD — needed for realistic detection/attack scenarios (failed logins, privilege escalation, lateral movement)
Version control	Git	Version history, recovery points, professional change-tracking workflow
Secrets storage	Separate <code>Secure/</code> container (<code>SOC-Secure.img</code>), never in Git	Documentation can be shared; secrets must never enter Git history (removing a secret later doesn't remove it from history)
AI assistance	ChatGPT (architecture/planning) + Claude Code (implementation/docs)	Support tools, not decision-makers — bounded by the AI Access Policy below

AI implementation & rules (binding on any AI assistant working on this project)

This project deliberately uses **two AI assistants for two different jobs**, and both operate under the same written policy. This section is the full, unabridged version of that policy — merged from `AI_ACCESS_POLICY.md` (which itself contains two historical drafts, "AI Access Policy" and "AI Assistant Security Policy", now reconciled here), `PROJECT_RULES.md`, and `CLAUDE.md` (the file that actually configures Claude Code's behavior in this repository).

WHY TWO ASSISTANTS, AND WHY SPLIT THIS WAY

Assistant	Role	Rationale
ChatGPT	Architecture, planning, troubleshooting <i>strategy</i>	Used for reasoning/design conversations before touching the lab
Claude Code	Terminal operations, documentation, scripts, implementation	Used for anything that actually touches files, VMs, or the filesystem — it has real tool access (shell, file read/write, network) that ChatGPT in this workflow doesn't

Both are **support tools, not decision-makers**. Every principle below applies to both, but Claude Code is the one with actual execution capability, so the operational rules (change procedure, credential handling, troubleshooting method) are written with it specifically in mind.

ROLE DEFINITION (FROM `CLAUDE.MD`)

Claude Code is instructed to act as **a junior SOC engineer and documentation assistant** — not an autonomous administrator. Required reading before any task, in order: `README.md` → `PROJECT_RULES.md` → `AI_ACCESS_POLICY.md` → `LAB_OVERVIEW.md` → `NETWORK.md` → `SERVERS.md` → `ACTIVE_DIRECTORY.md` → `SECURITY.md` → `docs/INDEX.md`. Documentation is treated as **more reliable than the assistant's own memory** — existing docs must be checked before assumptions are made, and previous decisions must be preserved, not silently overridden.

SOURCE OF TRUTH FOR AI BEHAVIOR

`README.md`, `PROJECT_RULES.md`, `AI_ACCESS_POLICY.md`, `docs/INDEX.md`, `docs/guides/`, `docs/troubleshooting/`, `docs/decisions/`, `docs/chat_history/`.

ALLOWED AI ACTIONS

- Read project documentation and analyze architecture/configurations
- Explain commands and security concepts
- Suggest improvements
- Review configurations
- Help write and maintain documentation
- Help troubleshoot problems (research, diagnosis, proposing fixes)
- Research

AI is explicitly not a replacement for administrator decisions — it assists; the human decides.

RESTRICTED — AI MUST NEVER

- Store, remember, or write down passwords, secrets, API keys, private keys, recovery codes, or tokens, in any file (Git-tracked or not)
- Commit credentials or secret files to Git
- Modify firewall rules or other critical infrastructure without approval

- Delete systems or files, or make any other destructive change, without confirmation
- Ignore or silently override previous documented decisions

CREDENTIAL HANDLING

- Credentials are **never** placed in Git, and never placed in normal markdown files — not even temporarily.
- Sensitive data (passwords, recovery codes, private keys, tokens) lives in a separate encrypted container: `Secure/SOC-Secure.img`, opened **manually by the administrator only** — an AI assistant should never open, read, or attempt to access it.
- The user enters passwords manually whenever one is required; an assistant should ask the human to do this rather than requesting the credential itself.
- Git itself is only ever used for documentation, configuration examples, scripts, and project history — never for anything in the "sensitive data" category above.

INFRASTRUCTURE CHANGE PROCEDURE

Before any infrastructure change, in this fixed order:

1. **Explain** what will change.
2. **Explain** the possible risk/impact.
3. **Create a backup or snapshot** where possible.
4. **Confirm approval** (explicit, not assumed).
5. **Execute** — apply the smallest change that achieves the goal.
6. **Document the result.**

This project's golden rule (from the top-level `README.md`): **no destructive changes without approval; all changes must be documented.**

TROUBLESHOOTING METHOD (MANDATED ORDER)

1. Check existing documentation first.
2. Identify the affected system.
3. Review previous troubleshooting cases for the same/similar symptom.
4. Explain the root cause once found.
5. Apply the smallest safe change.
6. Update documentation with the result.

AI PROJECT BEHAVIOR — GENERAL EXPECTATIONS

An AI assistant working on this project is expected to behave like a technical team member, specifically:

- Respect previous decisions instead of re-litigating them without new evidence.
- Preserve existing architecture rather than opportunistically redesigning it.
- Ask before destructive actions — even ones that are easy to undo.

- Document discoveries as they're made, not just at the end of a session.
- Prefer safe, reversible solutions over faster risky ones.
- Be technical but explain reasoning — when giving a command, explain what it does, and verify the result afterward rather than assuming success.

WHAT "READ-ONLY INVESTIGATION" COVERS IN PRACTICE

This master document itself is a working example of the policy's boundary: the 2026-07-13 verification pass used direct, read-only access already available on the host (`virsh` , ARP tables, unauthenticated port probes, existing passwordless SSH aliases, an unauthenticated HTTP GET) to confirm or correct facts — IP addresses, AD structure, running services. None of that required new credentials, changed any configuration, or touched anything destructively; it's squarely inside "analyze architecture/configurations" and "help write documentation." The one config file that *was* edited (`~/.ssh/config` , to fix a dead IP) is host tooling, not lab infrastructure, and the change was narrated as it happened rather than silently applied. Anything that would *change* the lab itself (firewall rules, AD objects, service state) still requires the explain → risk → backup → confirm → execute → document sequence above.

FINAL PRINCIPLE

The SOC Homelab should remain, at all times: **documented, reproducible, secure, and understandable**. Documentation first, automation second, security always.

Core security principles (from `docs/decisions/security_decisions.md` and `SECURITY.md`)

- **Least privilege** — separate admin vs. daily accounts; systems get only the permissions they need.
- **Defense in depth** — multiple security layers (OPNsense's boundary firewall + Security Onion's own hostgroup firewall + host-level controls).
- **Network isolation** — the whole 192.168.50.0/24 lab is isolated specifically because it contains attack tooling and deliberately vulnerable machines.
- **Documentation first, automation second** — every important change is recorded before/alongside being automated.
- **Backups before changes** — snapshots required before major infrastructure modifications.
- **Monitoring is core, not an add-on** — Security Onion provides the visibility foundation; "you can't improve what you can't see."
- **Controlled testing only** — all offensive testing stays inside the isolated lab boundary.

Incident response phases (from `SECURITY.md` , operationalized in the runbook — §6.2)

1. **Identification** — what happened, which systems, severity.
2. **Analysis** — collect logs, alerts, system info.
3. **Containment** — isolate affected systems, block malicious activity.
4. **Recovery** — restore services, verify security.

5. **Lessons learned** — document root cause, improvements, prevention.

5. Operational guides

5.1 Starting/stopping the lab

Preferred — desktop launchers (see [§5.5](#)):

- **Pentest Lab Start** — starts all 7 VMs in the correct order.
- **Pentest Lab Stop** — stops all VMs cleanly.

Command line:

```
~/Homelab/scripts/lab-start.sh
~/Homelab/scripts/lab-stop.sh
```

Single VM:

```
virsh -c qemu:///system start <vm-name>
virsh -c qemu:///system shutdown <vm-name> # use shutdown, not destroy, unless truly stuck
virsh -c qemu:///system list --all
```

Watch for the exact VM names in [§9](#) — note the leading space in `ATTACK-Kali`.

`lab-start.sh` starts all 7 VMs in order (OPNsense-FW, DC01, SOC-SecurityOnion, `ATTACK-Kali`, WIN11-01, ubuntu-server-01, Target-Metasploitable2), is idempotent (already-running VMs skipped), and wraps every `virsh` call in `timeout` so a stuck daemon can't hang the script.

`lab-stop.sh` stops clients/targets first, OPNsense and Security Onion last; polls each VM via ACPI shutdown, only force-killing via `virsh destroy` after a per-VM timeout (60s normal, 180s for Windows/Security Onion) and a clear warning; prints a final graceful-vs-forced summary.

5.2 Connecting to systems

Via the **SSH All Machines** launcher (opens one Konsole window with a real, independent tab per machine — see [§5.5](#)), or directly:

```
ssh opnsense
ssh dc01
ssh security-onion
ssh kali
ssh ubuntu-server
```

For GUI VM management: the **Homelab VM Manager** launcher opens virt-manager connected to `qemu:///system` (not the unrelated `qemu:///session` connection).

SSH key status: only `kali` and `security-onion` currently accept the local key passwordlessly. `opnsense`, `dc01`, and `ubuntu-server` prompt for a password (confirmed working interactively) —

run `ssh-copy-id <alias>` on any of them to enable passwordless login.

5.3 Security Onion / Kibana / Fleet in the browser

Via the **Security Onion Operator** desktop launcher, which opens a persistent, dedicated Chromium profile with every important page as its own tab (Overview, Hunt, Detections, Cases, Grid, Administration, PCAP, Kibana, Fleet). Built at `~/Homelab/browser/` (Playwright-based); see full design rationale below.

Why a persistent "daemon" browser instead of a fresh one per command: one long-running browser process exposes a local Chrome DevTools Protocol port (`127.0.0.1:9223` , never exposed beyond localhost); every tool (operator, audit script, future modules) attaches to that same process via CDP instead of launching its own. Only the process that started the daemon may close it.

First login: `scripts/soc-browser.sh` starts the daemon headed and waits (up to 10 minutes) for the login screen to disappear — it never sees or handles the password. Security Onion's own portal and Kibana/Fleet ("Welcome to Elastic") are **two separate logins**; expect to log into both once. After that, the session persists via the browser's own on-disk profile (`browser/profile/` , never in Git) for as long as the daemon runs or the profile exists — no script in this repo reads or copies cookies.

Revoking access: log out inside the browser (ends the session, profile files remain), or delete `browser/profile/` entirely (full reset).

⚠ A security incident during development (recorded, not swept under the rug): a script once used Playwright's `context.request` API to call a Fleet endpoint; the failed call's error/log formatting printed the full request headers — **including the live session cookie** — into terminal output visible in that session's transcript. Not a leak to any third party (private, isolated-network conversation), but exactly the kind of exposure this project exists to avoid. Response: the affected daemon was restarted immediately (invalidating that session), and every API call now goes through `lib/browser.mjs`'s `fetchJsonInPage()` , which runs `fetch()` *inside* the already-authenticated page via `page.evaluate()` — cookies are attached by the browser itself and never pass through this project's Node code or its error formatting. `context.request` (or any raw-HTTP-call API outside the page) should not be reintroduced without the same care.

Read-only guarantee: everything built so far (navigation, screenshots, the audit's GET-only API calls) is read-only. Nothing can modify Fleet, agent policies, detection rules, ingest pipelines, Elasticsearch, Kibana saved objects, or Security Onion's own configuration — any future module that *would* touch those needs a proposal and explicit approval first.

Fleet status without touching the browser manually:

```
~/Homelab/scripts/soc-web-audit.sh
```

Generates a Markdown report in `browser/artifacts/` covering: SO/Kibana reachability and login state, per-agent Fleet status (online/offline/unhealthy, DC01 called out specifically), data-stream freshness (Windows Event Logs, Sysmon, Suricata), Grid member status, and a Detections-page summary. Requires the daemon already running and logged in. Known gaps: Cases/Hunt event-level content isn't searched yet (Fleet/data-stream metadata only); SSH correlation with actual OS-level

state isn't automated; ingest-pipeline detail isn't pulled (Kibana's `index_management` API returned "not available" on this install).

5.4 Network ports & firewall hostgroups reference

Security Onion's **own** firewall (separate from OPNsense) — reconstructed 2026-07-13 directly from `/opt/so/saltstack/default/salt/firewall/defaults.yaml` and `soc_firewall.yaml`, because this exact gap caused the DC01 outage (see [§7.6](#)).

Portgroups → **ports**:

Portgroup	Port(s)	Purpose
<code>elastic_agent_control</code>	TCP 8220	Fleet Server checkin
<code>elastic_agent_data</code>	TCP 5055	Data ingest (logs/events)
<code>elastic_agent_update</code>	TCP 8443	Agent updates
<code>endgame</code>	TCP 3765	Elastic Defend/Endpoint output ("Endgame" = Elastic's historical product name)
<code>beats_5044</code> / <code>beats_5644</code> / <code>beats_5066</code> / <code>beats_5056</code>	TCP 5044 / 5644 (SSL) / 5066 / 5056	Logstash beats input
<code>kibana</code>	TCP 5601	Kibana web UI
<code>elasticsearch_rest</code>	TCP 9200	Elasticsearch REST API
<code>elasticsearch_node</code>	TCP 9300	Elasticsearch node-to-node
<code>docker_registry</code>	TCP 5000	Internal Docker registry
<code>influxdb</code>	TCP 8086	Metrics
<code>postgres</code>	TCP 5432	PostgreSQL
<code>all</code>	TCP/UDP 0–65535	Fully trusted hostgroups (e.g. <code>anywhere</code>)

Key hostgroups:

Hostgroup	Typically for	Grants access to
<code>analyst</code>	People using the web UI	nginx web UI (443), Kibana (5601)
<code>fleet</code>	Fleet Server itself	Various Fleet-related ports
<code>elastic_agent_endpoint</code>	Windows/Linux machines running Elastic Agent	Fleet checkin (8220)
<code>beats_endpoint</code> / <code>beats_endpoint_ssl</code>	Machines shipping logs via beats	Data ingest (5055 + beats ports), TLS variant
<code>endgame</code>	Machines with Elastic Defend	Endpoint output (3765)
<code>elasticsearch_rest</code>	Systems talking directly to Elasticsearch	9200
<code>manager</code> / <code>receiver</code> / <code>sensor</code> / <code>standalone</code>	Internal Security Onion grid roles	Role-specific ports
<code>desktop</code>	Admin workstations	Like <code>analyst</code> , plus extras
<code>customhostgroup0</code> – <code>9</code>	Free to define	—

Rule of thumb — what a new endpoint needs:

Want to...	Need hostgroup
View the web UI/Kibana	<code>analyst</code>
Have Elastic Agent check into Fleet	<code>elastic_agent_endpoint</code> (or <code>fleet</code>)
Ship logs via Elastic Agent	<code>beats_endpoint</code>
Get Elastic Defend telemetry working	<code>endgame</code>

A normal Windows/Linux endpoint with Elastic Agent needs *at minimum* all three of `elastic_agent_endpoint` , `beats_endpoint` , and `endgame` — `analyst` alone is not enough, even though that seems logical. Membership in one hostgroup grants nothing in another.

Adding a system to a hostgroup (on Security Onion, as root):

```
sudo so-firewall includehost <hostgroup-name> <ip-address>
sudo so-firewall apply
```

Example (what was done for DC01 on 2026-07-13):

```
sudo so-firewall includehost elastic_agent_endpoint 192.168.50.10
sudo so-firewall includehost beats_endpoint 192.168.50.10
sudo so-firewall includehost endgame 192.168.50.10
sudo so-firewall apply
```

This is **additive** — it does not remove the IP from hostgroups it's already in. To remove entirely: `sudo so-firewall removehost <ip>`.

Read-only inspection (no root needed):

```
cat /opt/so/saltstack/default/salt/firewall/defaults.yaml
cat /opt/so/saltstack/default/salt/firewall/soc_firewall.yaml
cat /opt/so/log/so-firewall.log
ss -tlnp                                # confirm a port is actually listening
```

From another system (e.g. DC01, PowerShell): `Test-NetConnection -ComputerName 192.168.50.30 -Port 8220`.

5.5 Desktop launchers

Four one-click launchers (symlinked to `~/Desktop/` and `~/.local/share/applications/`), replacing several earlier, discarded attempts (2026-07-09, -10, -12).

Launcher	Runs	Purpose
Pentest Lab Start	<code>konsole --hold -e lab-start.sh</code>	Starts all 7 VMs in order
Pentest Lab Stop	<code>konsole --hold -e lab-stop.sh</code>	Stops all 7 VMs cleanly
SSH Alle Machines	<code>lab-ssh-all.sh</code>	One Konsole window, one real independent tab per machine
Homelab VM Manager	<code>flatpak run org.virt_manager.virt-manager --connect qemu:///system</code>	virt-manager on the correct (system) connection
Security Onion Operator	(separate — §5.3)	Persistent browser session for SO/Kibana/Fleet

`--hold` keeps Start/Stop windows open after completion so the summary stays readable. All terminal launchers use **Konsole** specifically — Bazzite doesn't have `gnome-terminal` installed, and earlier launchers written for it silently did nothing.

Why SSH Alle Machines isn't just `konsole -e`: the first version used `tmux` in a single tab — impractical (only one connection visible, password entry required switching `tmux` windows). Rebuilt on Konsole's native `--tabs-from-file` with `--separate` (without which new invocations pile tabs onto whatever Konsole window is already open). Because the script itself must call `konsole`, the launcher's `Exec=` runs the script directly rather than wrapping it in an outer `konsole -e` (doing both opens two windows). **Known cosmetic quirk**: an extra tab titled after the working directory sometimes appears — this is Konsole's own session-restore behavior, not something the script creates; harmless.

SSH config (`~/.ssh/config`, rebuilt 2026-07-12 from live-verified addresses):

Alias	Host	User	Verified
opnsense	192.168.50.1	root	SSH confirmed, password prompt
dc01	192.168.50.10	Administrator	Port confirmed open; username not fully verified
security-onion	192.168.50.30	socadmin	Confirmed, key auth works
kali	192.168.50.50	blue1	Confirmed, key auth works
ubuntu-server	192.168.50.40	ubuntu	Port confirmed open; username not fully verified

WIN11-01 was checked and excluded (port 22 doesn't respond — normal for a Windows 11 client). Two older, stale aliases (`onion` at .9, `kali` at .157) were removed — both addresses had moved.

A real bug found and fixed while building this: testing `lab-start.sh` / `lab-stop.sh` exposed a **libvirtd deadlock** in the existing `soc-mirror.sh` libvirt hook — it called back into `virsh` *synchronously* from inside libvirtd's own event handling, which could hang libvirtd until manually restarted. Fixed by running the reconciler fully detached via `systemd-run --no-block --collect` (falls back to `nohup`). Verified: a full 7-VM stop/start cycle now completes in under two minutes with `virsh` staying responsive throughout.

5.6 Quick reference — common operations

```
# Generate a Sysmon test event on DC01 (via SSH) to confirm telemetry flow
Start-Process -FilePath 'cmd.exe' -ArgumentList '/c echo test' -Wait

# Then check in Security Onion Hunt (window: Last 15 Minutes):
host.name:"dc01" AND event.dataset:"windows.sysmon_operational"

# Traffic-mirroring status
~/Homelab/scripts/soc-mirror.sh --status

# Security Onion firewall log
ssh security-onion "cat /opt/so/log/so-firewall.log | tail -20"
```

6. Detection use cases & incident response

6.1 What this SOC should detect

Status labels:  present (Security Onion has built-in Suricata/Sigma coverage, works once traffic/logs arrive) ·  should be present via default rulesets but not yet deliberately triggered/confirmed in this lab ·  requires custom configuration/rules not yet built.

Network reconnaissance (Suricata/Zeek):

Detection	Status
ICMP ping sweeps	
TCP SYN/FIN/NULL/XMAS scans	 (requires traffic to actually reach Security Onion via <code>monitor-net</code>)
UDP scans	
OS fingerprinting / banner grabbing	 (visible in Zeek connection logs, no dedicated alert rule)

Login attempts (Windows Event Log / Sysmon / Suricata):

Detection	Status
SSH brute force	 (Suricata rules present)
FTP brute force	
SMB brute force	 (relevant especially toward DC01; Windows Security-channel logs contribute input since 2026-07-13)
Suspicious DNS requests	 (Zeek logs network DNS; Sysmon event ID 22 on DC01 logs local DNS queries since 2026-07-13)

Known attack techniques:

Detection	Status
Known exploit signatures	 (Suricata ET Open / other rulesets, depending on subscription)
Reverse shells	 (network-side via Suricata, host-side via Sysmon process-creation events since 2026-07-13)
Metasploit/Meterpreter indicators	 (known Suricata signatures)
SQLi / command injection / directory traversal	 (Suricata web-attack rulesets)

Host-based detection (Sysmon/Elastic Defend on DC01, since the 2026-07-13 install):

Sysmon Event ID	Meaning	Status
1	Process Create	✓ confirmed with test events
3	Network Connection	✓ confirmed with test events
11	File Create	✓ confirmed with test events
22	DNS Query	✓ confirmed with test events
Other (registry, image load, etc.)	Various	⚠ covered by the SwiftOnSecurity config, not individually tested

Elastic Defend (Elastic Agent's built-in endpoint security) also produces its own detections on DC01 since the 2026-07-13 firewall fix.

How to test a detection (Purple Team style): run a harmless version of the attack from Kali or another lab VM, then check Security Onion's Hunt/Detections page. Example — simulated SSH brute force against ubuntu-server-01:

```
for i in 1 2 3 4 5; do
    ssh -o ConnectTimeout=3 -o BatchMode=yes nonexistentuser@192.168.50.40
done
```

Then in Hunt: `destination.ip:"192.168.50.40" AND event.dataset:*ssh*`

6.2 Incident response runbook

A fixed, ordered procedure for any Security Onion alert — real attack, test, or Purple Team exercise. Steps are not to be skipped, even for something that looks harmless.

Step 1 — Confirm something real happened. Go to Security Onion → Alerts/Detections. Which rule fired? Source/destination IP? When (note: SO displays local Dutch time, +02:00 in summer)? How often?

Step 2 — Put it in context. In Hunt, search broadly around the same IP/time:

```
source.ip:"<IP>" OR destination.ip:"<IP>"
```

Is this IP a system that's supposed to exist in this lab ([§9](#))? Was a deliberate test/exercise running at that time (check `docs/daily/`)? Did anything else happen around the same time?

Step 3 — Look at the host itself (if it's a known lab system with SSH access): `ssh dc01` and review local logs/processes, and (for DC01 specifically) Sysmon events around the timestamp. **Boundary:** investigating (reading, searching, comparing) is always fine to do independently. Changing configuration, restarting services, or isolating something requires — unless already agreed otherwise — a short explanation of intent first.

Step 4 — Record what you found. Even if it turns out to be a test or false alarm, write it up in that day's report (`docs/daily/YYYY-MM-DD/rapport.md`): what the alert was, what was checked, the

conclusion (real/test/false alarm/unclear). If it's a genuine *new* technical problem (not an attack, e.g. the DC01 Fleet case), also create a `docs/troubleshooting/` document with the same evidence standard as §7.6: problem, cause, fix, how it was tested.

Step 5 — If it's a real threat (even inside this isolated lab): 1) don't panic — the lab is isolated from the rest of the network; 2) consider isolating the system (e.g. detach its network interface via `virsh`) — explain first unless broader approval already exists for that specific system/action; 3) preserve evidence before cleaning up (screenshots, event IDs, IPs, times); 4) document as in Step 4.

Quick Hunt searches:

Looking for	Query
Everything from one host	<code>host.name:"<name, lowercase>"</code>
Only Windows events from a host	<code>host.name:"<name>" AND event.module:"windows"</code>
Sysmon events specifically	<code>host.name:"<name>" AND event.dataset:"windows.sysmon_operational"</code>
Traffic to/from an IP	<code>source.ip:"<ip>" OR destination.ip:"<ip>"</code>
Last 15 minutes	set the time picker (top right) to "Last 15 Minutes"

⚠ **Case note:** hostnames are indexed lowercase in Security Onion (`dc01` , not `DC01`), even though the Fleet page displays it capitalized.

6.3 Detection validation plan

Status: planned, execution deferred to the same dedicated session as §12. Every ⚠ row in §6.1 has a real, concrete cause: it hasn't been deliberately triggered and checked in Hunt yet, not that it's known to be broken. This plan maps each one to the specific test that will close it, reusing the attack-scope tiers already agreed in §12 rather than inventing a separate test pass.

Method for every row below (Purple Team style): run the technique from Kali (or the relevant lab VM) → immediately check Security Onion Hunt/Detections for a matching alert → record the result by flipping the status to ✅ (fired as expected) or ❌ (didn't fire — becomes a real detection-engineering task, not just a documentation update) → note the exact Hunt query and evidence used, so it can be reproduced.

§6.1 item	Test that validates it	Covered by
ICMP ping sweeps	<code>nmap -sn 192.168.50.0/24</code> from Kali (already dry-run once informally, 2026-07-13 — not yet checked against Hunt)	Tier 1
TCP SYN/FIN/NULL/XMAS scans	<code>nmap -sS / -sF / -sN / -sX</code> against Metasploitable2	Tier 1
UDP scans	<code>nmap -sU</code> against Metasploitable2	Tier 1
OS fingerprinting / banner grabbing	<code>nmap -O</code> , <code>nc</code> / <code>nmap -sV</code> banner grabs	Tier 1
SSH brute force	Repeated failed SSH logins against ubuntu-server-01 or Metasploitable2 (example command already in §6.1)	Tier 1/2
FTP brute force	Failed logins against Metasploitable2:21 (vsftpd)	Tier 2
SMB brute force	Failed SMB auth — against Metasploitable2 first (no risk); against DC01 only as part of the Tier 3 AD chain, since that's identity-sensitive	Tier 2 now, Tier 3 for DC01 specifically
Suspicious DNS requests	DNS queries for known-bad-looking / high-entropy domains from Kali, cross-checked in Zeek <code>dns.log</code> and (for DC01) Sysmon event ID 22	Tier 1
Known exploit signatures	<code>vsftpd_234_backdoor</code> and <code>usermap_script</code> Metasploit modules against Metasploitable2 (first one repeats the historical exploit from §8 — good regression test)	Tier 2
Reverse shells	Any Metasploitable2 exploit that pops a shell (network-side Suricata check now; host-side Sysmon check once WIN11-01 is a target, per §12)	Tier 2 (network), Tier 3 (host)
Metasploit/Meterpreter indicators	Meterpreter payload during the Metasploitable2 exploitation pass	Tier 2
SQLi / command injection / directory traversal	Juice Shop's own scored OWASP Top 10 challenges (SQLi login bypass, directory traversal, etc.)	Tier 2
Sysmon "other" event IDs (registry, image load, etc.)	Targeted test actions on a monitored Windows host (registry key change, DLL load) — needs a Sysmon-monitored <i>target</i> host, which is exactly what WIN11-01 becomes after the §12 cleanup; DC01 could also be used sooner since it already has working Sysmon telemetry	Can start immediately on DC01, or wait for WIN11-01

Also planned — a dry run of the incident-response runbook (§6.2) itself, not just individual detections: pick one alert generated during the Tier 1/2 pass and walk it through Steps 1–4 for real (confirm → context → host check → write-up in `docs/daily/`), to confirm the runbook is actually usable in practice, not just on paper.

Definition of done for this plan: every row above has a  or  (with evidence) instead of , and at least one full runbook dry-run is logged in `docs/daily/` . At that point §6.1's status table gets updated to match, and this subsection can be marked complete.

7. Troubleshooting history

Real problems encountered building this lab, in chronological/topical order, with evidence and fixes. This section preserves technical detail exactly — do not treat the summaries below as a substitute for the source documents when replaying a fix.

7.1 QEMU guest agent not configured

System: DC01. **Symptom:** `sudo virsh qemu-agent-command DC01 '{"execute":"guest-ping"}'` → `error: argument unsupported: QEMU guest agent is not configured`. **Cause:** the guest agent wasn't installed/enabled inside the VM, and the QEMU channel wasn't configured. **Fix:** install the guest agent inside the guest OS, enable its service, configure the VM channel, restart, retest. **Lesson:** a running VM doesn't imply guest integration works — test it explicitly before relying on guest-management features.

7.2 virt-manager VM setup issues

System: Bazzite host. Storage: standardized on qcow2 (snapshots, thin provisioning, flexible management). One image converted from VMDK via `qemu-img convert -f vmdk -O qcow2`. Display: SPICE fullscreen/resolution issues traced to guest-integration tooling rather than hardware. **Lessons:** document VM hardware settings, snapshot before risky changes, test networking before installing services on a new VM.

7.3 OPNsense network debugging

Systems: OPNsense, DC01, Security Onion. General findings: a firewall problem can *look* like an application, server, or DNS problem — always verify network layers (interface → IP → gateway → DNS → firewall rules) from the bottom up before assuming a higher-layer cause. DNS misconfiguration was repeatedly the real root cause behind apparent Active Directory problems. **Test commands:** `ping 192.168.50.1` (OPNsense), `ping 192.168.50.10` (DC01), `nslookup <hostname>`.

7.4 Security Onion installation

System: Security Onion VM. Resourcing note: SOC platforms need materially more RAM/CPU/storage than an ordinary server — under-provisioning caused early performance concerns. Admin account: `socadmin`, kept separate from personal/daily accounts. Core lesson: a SOC platform is only as useful as the telemetry reaching it — network visibility and log-source planning have to happen *before* detection engineering, not after.

7.5 DC01 Active Directory setup

System: DC01, 192.168.50.10. Confirmed early: DNS is the foundation Active Directory depends on — most AD problems trace back to DNS. Setup order: static IP → hostname → network connectivity

verified → AD DS + DNS roles installed → promoted to Domain Controller (new domain, pentest.lab) → account tiers planned (Domain Admin / Server Admin / SOC Admin / Standard User).
Lesson: take a snapshot before promoting to DC — this step is hard to cleanly undo.

7.6 DC01 Fleet health & Sysmon telemetry (2026-07-13)

The largest, most thoroughly evidenced troubleshooting case in the project — three independent, stacked root causes behind one symptom ("DC01 Offline in Fleet, no Windows/Sysmon telemetry").

This was a recurring issue. On 2026-07-10, the same symptom (DC01 unable to reach Fleet Server on 8220; Elastic Defend stuck `DEGRADED`) was already diagnosed once and "fixed" with a direct, non-persistent rule:

```
sudo iptables -I DOCKER-USER 1 -s 192.168.50.10/32 -p tcp --dport 8220 -j ACCEPT
```

This bypassed Security Onion's salt-managed firewall config entirely, so any later `so-firewall apply` or SO reboot silently discarded it — which is almost certainly why the identical symptom reappeared by 2026-07-13. Elastic Defend's `DEGRADED` status was investigated on 07-10 without finding a network cause and was deliberately parked; it turned out to share the same root-cause category (a missing hostgroup, `endgame` /port 3765).

Root cause 1 — firewall hostgroups. DC01 could reach TCP 443 (web/Kibana, gated by `analyst`) but not 8220 (Fleet checkin) or 5055 (data ingest) — connections timed out. `ss -tlnp` on Security Onion confirmed the ports *were* listening, ruling out "service down" and pointing at a firewall drop. `/opt/so/log/so-firewall.log` showed DC01 had only ever been added to `analyst` (on 2026-07-10), never to `elastic_agent_endpoint`, `beats_endpoint`, or `endgame`. **Fix:**

```
so-firewall includehost elastic_agent_endpoint 192.168.50.10
so-firewall includehost beats_endpoint 192.168.50.10
so-firewall includehost endgame 192.168.50.10
so-firewall apply
```

Additive only — DC01 was not removed from `analyst`. **Verified:** `Test-NetConnection` to 8220/5055/3765 all `True`; Fleet's `endpoint` component went from `DEGRADED` (`Unable to connect to output server`) to `HEALTHY`; survived a full Security Onion reboot (rules re-applied from the salt-managed pillar, not a runtime-only iptables state) and a full DC01 reboot.

Root cause 2 — ~9-hour clock skew on DC01. After the firewall fix, DC01 checked into Fleet correctly — but after a DC01 reboot, all Fleet components got stuck in `STARTING` indefinitely. Comparison: DC01 UTC: 2026-07-13 10:55:19 vs Security Onion UTC: 2026-07-13 01:55:20. `w32tm /query /status` showed `Source: Local CMOS Clock` — no NTP sync configured; as the domain's PDC Emulator, DC01 is expected to be an authoritative time source rather than an ordinary NTP client, so it was never pulling correct time from anywhere. First attempt (`w32tm /config /manualpeerlist:"pool.ntp.org,0x8" ...` + forced resync) fixed the current boot but **the skew came back on a second reboot** — the registry config persisted, but the service never synced early enough after boot. Real cause: `vmictimesync` (a Hyper-V-compatible time-sync integration service,

also active under QEMU/KVM's Hyper-V-enlightenment emulation) was set to `Manual` start and overriding/racing NTP at boot. **Final, persistent fix:**

```
Stop-Service vmictimesync -Force
Set-Service vmictimesync -StartupType Disabled
w32tm /resync /force
```

Plus a defense-in-depth scheduled task forcing `w32tm /resync /force` 30 seconds after every startup. **Verified:** two additional full reboots with zero manual intervention, clock matched Security Onion's within 1 second each time. **Side effect discovered:** the clock skew had also been silently poisoning the Logstash → Elasticsearch pipeline — events shipped while the clock was wrong got `@timestamp` values ~9 hours in the future, which Elasticsearch rejected, routing them to Logstash's dead-letter queue (`dlq_routed: 1917` , confirmed static/non-growing after the clock fix — old poisoned backlog, not ongoing). This is the real reason winlog-sourced datasets never appeared in Security Onion even though the Elastic Agent itself reported those inputs `HEALTHY` — the agent successfully shipped the events, but Elasticsearch silently rejected them downstream. **Lesson:** an agent-side `HEALTHY` status only proves the agent believes it's shipping data, not that it was accepted.

Root cause 3 — Sysmon never installed. `Get-Service *sysmon*` → nothing; the Sysmon-Operational event log didn't exist. Security Onion's own Fleet policy already explicitly subscribed to the `windows.sysmon_operational` dataset — it was waiting for data that could never arrive. **Fix:** downloaded Sysmon from the official Sysinternals source (signature verified: `Valid` , `CN=Microsoft Windows Publisher`), downloaded the SwiftOnSecurity config (schema 4.50, still the de-facto SOC standard — Sysmon's schema is additive, so this remains valid on newer builds), installed via `Sysmon64.exe -accepteula -i sysmonconfig.xml` (installed v15.21, schema 4.91). **Verified:** local test events (process create, DNS query, file create, network connection) all logged with correct event IDs (1/22/11/3); Fleet's `windows.sysmon_operational` sub-stream went `STARTING` → `HEALTHY` without an agent restart; confirmed end-to-end in Hunt matching the exact test actions; survived an Elastic Agent service restart (~5 min to stabilize vs ~2 min for a VM reboot) and two full DC01 reboots (1,816 new sysmon events in the 15 minutes after the second reboot, including the literal boot process tree).

Additional change: DC01's Windows timezone set to `W. Europe Standard Time` per request — cosmetic only, the underlying UTC clock remains authoritative.

Full verification summary:

Check	Result
Fleet UI shows DC01	Healthy
All Fleet components (endpoint, winlog, osquery, windows/metrics, filestream)	HEALTHY
TCP 8220/5055/3765 reachable from DC01	Confirmed
Firewall config persistent across SO reboot	Confirmed
DC01 clock matches SO clock after 2 independent reboots, no manual fix	Confirmed
Sysmon service + event channel	Running / exists
Sysmon events reach Security Onion	Confirmed via Hunt
Survives Elastic Agent restart	Confirmed
Survives DC01 reboot (×2)	Confirmed
Survives Security Onion reboot	Confirmed

Rollback procedures (kept for reference, not expected to be needed):

```
# Firewall – removes DC01 from ALL hostgroups, then optionally re-add only analyst:
so-firewall removehost 192.168.50.10
so-firewall includehost analyst 192.168.50.10
so-firewall apply
```

```
# Clock / vmictimesync
Set-Service vmictimesync -StartupType Manual
Unregister-ScheduledTask -TaskName 'Force-NTP-Resync-At-Boot' -Confirm:$false
w32tm /config /syncfromflags:domhier /update
Restart-Service w32time
```

```
# Sysmon
C:\Tools\Sysmon\Sysmon64.exe -u force
Remove-Item -Recurse -Force C:\Tools\Sysmon
```

```
# Timezone
Set-TimeZone -Id 'Pacific Standard Time' # or whatever the original was
```

General lessons from this case:

- A "Healthy/Offline" Fleet status can have multiple independent, stacked root causes — each fix can look complete until the next reboot re-exposes the next layer. Validate across a real reboot cycle, not just current running state.
- Agent-reported **HEALTHY** proves the agent believes it's shipping data, not that Elasticsearch accepted it — the Logstash DLQ counter was the key signal here.

- Domain Controllers (especially the PDC Emulator) don't behave like ordinary NTP clients by default.
- Security Onion's per-hostgroup firewall model means reachability on one port says nothing about reachability on a different, differently-gated port — each integration's hostgroup requirement must be checked explicitly.

7.7 The `soc-mirror.sh` libvirtd deadlock (found while building the launchers)

See [§5.5](#) — a synchronous callback from a libvirt qemu hook into `virsh` could deadlock libvirtd itself. Fixed by detaching the reconciler via `systemd-run --no-block --collect`.

7.8 libvirt/OPNsense DHCP conflict (2026-07-09)

See [§8](#) — libvirt's own DHCP on `pentest-lab` collided with OPNsense's, and the `virbr10` bridge itself claimed OPNsense's own IP (192.168.50.1). Fixed by stripping libvirt's `<ip>` / `<dhcp>` sections from the network definition entirely (OPNsense became the sole DHCP/DNS/gateway layer) and giving the Bazzite host a separate management IP (192.168.50.254/24) on `virbr10`, restored automatically at boot by `fix-virbr10-ip.service`.

8. Project timeline

Period	Project name	What happened
Before 2026-07-05	Fortress Bazzite	Initial setup: virt-manager, Kali/Debian, Ubuntu Server, Metasploitable2, Docker, Juice Shop, Burp Suite, Metasploit. Design document written planning a Suricata + Zeek + Wazuh stack.
2026-07-03 – 07-07	Fortress Bazzite	Kali/Metasploitable2 VMs stood up (VirtIO incompatibility fixed via i440FX+SATA+e1000); first <code>nmap</code> scans; isolated <code>pentest-lab</code> network built (<code>virbr10</code> , 192.168.50.0/24). Metasploitable2 enumerated (Nmap, Gobuster, Nikto, smbclient, enum4linux-ng). Metasploit set up; <code>vsftpd_234_backdoor</code> exploited → Meterpreter session. Ubuntu Server + Docker + Juice Shop added; first vuln found via Burp Suite (SQLite disclosure). Intel AX210 wifi passed through to Kali via PCI-passthrough (requests for monitor-mode/injection/cracking were declined by the assistant; only theoretical/defensive guidance given). BIOS VT-x/VT-d confirmed enabled (07-05). Suricata installed directly on the Bazzite host itself (not a VM), watching <code>enp6s0</code> and <code>virbr10</code> ; custom test rules (ICMP, Nmap SYN scan) confirmed via <code>eve.json</code> / <code>fast.log</code> ; a bash/Python watcher script built, with plans for a full curses/Qt dashboard ("FORTRESS IDS v2") — this became a separate side project (<code>/var/home/Joost/FORTRESS/</code> , still present on disk, not part of this repo). OPNsense installed for the first time (07-07); first attempt hung in live-media mode, redone with ZFS; WAN connectivity/DHCP issues left open at period end.
2026-07-08	Transition to "SOC Homelab"	⚠ Reconstructed from limited evidence (one firewall-log line). The full 192.168.50.0/24 network was added to Security Onion's <code>analyst</code> hostgroup.
2026-07-09	—	First git commit (<code>3ab5374</code> , 18:53:51, "Initial SOC homelab baseline"). Major network-recovery day: found and fixed a libvirt-vs-OPNsense DHCP conflict and a <code>virbr10</code> IP collision with OPNsense itself (see §7.8); Kea DHCP reservations created for all VMs; desktop launchers fixed for KDE/Konsole (were written for GNOME Terminal); lab-start/stop scripts corrected to real VM names including the <code>ATTACK-Kali</code> space. End of day: ping/SSH to OPNsense working, Start/Stop launchers working, clean DNS/DHCP structure (OPNsense as sole authority).
2026-07-10	—	DC01 fully built (Windows Server + AD DS + DNS, promoted to DC, users/accounts created) and connected to Security Onion via Fleet (agent enrolled 11:18:17). First Fleet connectivity problem found and "fixed" with a non-persistent <code>iptables</code> rule (see §7.6 for why this didn't last). Elastic Defend <code>DEGRADED</code> investigated, no cause found, deliberately parked.
2026-07-11	—	Full documentation structure created: README, project rules, AI access policy, network/server/AD documentation, troubleshooting history.
2026-07-12	—	Secret (<code>Secure/SOC-Secure.img</code>) scrubbed from git history. Desktop launchers built properly (replacing several earlier discarded attempts). Event-driven traffic mirroring (<code>soc-mirror.service</code>) rewritten, fixing the libvirtd deadlock bug. Browser automation for Security Onion built.
2026-07-13	—	DC01's Fleet outage fully, persistently resolved (firewall hostgroups + clock/ <code>vmctimesync</code> + Sysmon install — §7.6). Documentation structure substantially

Period	Project name	What happened
		expanded: daily reports, asset inventory, glossary, network/port reference, incident-response runbook, detection use cases, and this master document. Commit <code>2f40b20</code> ("Fix DC01 Fleet health and add Sysmon telemetry") made but not pushed , per the user's standing instruction to never push without explicit permission.

9. Asset inventory

Full detail: `docs/ASSET_INVENTORY.md` . Reliability labels:  verified this session / hard evidence,  not reverified this session.

Physical host

Property	Value	Status
OS	Bazzite Linux	
CPU	Intel Core i9-11900K (8 cores / 1 socket)	 live-verified 2026-07-13 (<code>lscpu</code>)
GPU	NVIDIA GeForce RTX 3090 (GA102)	 live-verified 2026-07-13 (<code>lspci</code>)
RAM	62 GiB	 live-verified 2026-07-13 (<code>free -h</code>)
WiFi	Intel AX210 (Wi-Fi 6E)	 card confirmed; PCI-passthrough to Kali not reconfirmed
Virtualization	KVM, QEMU, libvirt, virt-manager	
Other	Docker / OWASP Juice Shop	 not found on the host itself — Juice Shop is confirmed live on <code>ubuntu-server-01</code> instead

Virtual machines

VM name (virsh)	IP	SSH alias	SSH user	OS / role	Status
OPNsense-FW	192.168.50.1	opnsense	root	OPNsense firewall/gateway	✓
DC01	192.168.50.10	dc01	Administrator	Windows Server 2022, AD DC (PDC Emulator), domain pentest.lab	✓
WIN11-01	192.168.50.20	(none)	—	Windows 11 workstation, domain-joined as DESKTOP- EFKB8GQ , firewall blocks SMB/RDP/WinRM	✓
SOC- SecurityOnion	192.168.50.30	security- onion	socadmin	Security Onion 3.1.0 standalone	✓
ubuntu-server- 01	192.168.50.100 (corrected, was .40)	ubuntu- server	ubuntu (key auth not set up)	Linux server, live OWASP Juice Shop on :3000	✓
ATTACK-Kali (leading space)	192.168.50.50	kali	blue1	Kali Linux, Red Team workstation	✓
Target- Metasploitable2	192.168.50.70 (now verified)	(none)	—	Metasploitable2, vulnerable target — stock port fingerprint confirmed	✓

Virtual networks

Name	Type	Purpose	Status
pentest-lab	Isolated bridge	Main network, 192.168.50.0/24	✓
monitor-net	Isolated bridge, no IP addressing	Traffic mirroring to Security Onion	✓
default	Standard libvirt network	Not used by lab VMs	✓

Active Directory identity inventory

✓ Live-verified 2026-07-13 via read-only `dsquery` over the `dc01` SSH alias. Full detail and gaps: [§3.3](#) and `ACTIVE_DIRECTORY.md`.

OU	Accounts
Domain Controllers	DC01
Admins	IT Admin 01 (not actually in Domain Admins)
AD-Users	soctest, Helpdesk 01, Employee 01, Manager 01, HR 01, Finance 01
Service-Accounts	SQL Service
Workstations	(empty)
Servers	(empty)

Custom groups: SOC-Analysts (member: soctest), Helpdesk (no members). Domain Admins = built-in Administrator only.

Software versions

Component	Version	Status
Security Onion	3.1.0	✓
Elastic Agent (on DC01)	9.3.3+build202604082258	✓
Sysmon (on DC01)	15.21 (schema 4.91)	✓, installed 2026-07-13
Sysmon config	SwiftOnSecurity, schema 4.50	✓
Windows Server (DC01)	Windows Server 2022 Standard Evaluation	✓

Desktop launchers (on the Bazzite host)

Launcher	Purpose
Pentest Lab Start	Starts all lab VMs in order
Pentest Lab Stop	Stops all lab VMs cleanly
SSH Alle Machines	Konsole tab per system with SSH access
Homelab VM Manager	virt-manager on qemu:///system
Security Onion Operator	Browser window with all key SO/Kibana/Fleet pages as tabs

Access methods (no passwords stored here)

Method	Used for
SSH keys (<code>~/ .ssh/config</code>)	dc01, security-onion, kali — confirmed passwordless 2026-07-13. <code>opnsense</code> and <code>ubuntu-server</code> are configured but currently not passwordless (see open items).
Browser session (Playwright, dedicated profile)	Security Onion web UI, Kibana, Fleet
<code>virsh -c qemu:///system</code>	VM management from the hypervisor itself

Open verification items

Resolved this session (were open, now closed — see inline notes throughout this document): `Target-Metasploitable2` 's IP, `ubuntu-server-01` 's real IP and live role, `WIN11-01` 's domain-join status and network exposure, the host's hardware specs, and the AD OU/group/user structure.

Still open:

- `opnsense` **SSH is not passwordless** despite `docs/PROJECT_STATUS.md` documenting it as working — `Permission denied` on 2026-07-13. Needs manual investigation (web UI, or re-establish key auth).
- `ubuntu-server-01` **SSH key login doesn't work** — port 22 is open and confirmed Ubuntu, but authentication fails; a password or a fresh `ssh-copy-id` is needed.
- Exact DHCP ranges and DNS forwarders on OPNsense (blocked on the SSH item above).
- PCI-passthrough of the WiFi card to Kali — card presence confirmed, passthrough itself not reconfirmed.
- The *intended purpose* of WIN11-01 within training scenarios (technical facts are now known; the "why" is a scope decision — see [§12](#)).

10. Glossary

Active Directory (AD) — Microsoft's system for managing users, computers, and permissions within an organization ("domain"). Runs on **DC01** here; domain is `pentest.lab`.

Agent (see also Elastic Agent) — a small program running on a computer that collects and forwards data (logs, metrics, events) to a central system.

Beats — Elastic's family of lightweight data shippers (e.g. Winlogbeat, Metricbeat). In modern Elastic deployments these typically run *inside* Elastic Agent rather than standalone.

CEST / CET — Central European (Summer) Time. CET = UTC+1 (winter), CEST = UTC+2 (summer). The Netherlands uses CEST late March–late October.

Dead Letter Queue (DLQ) — where Logstash puts documents it couldn't store in Elasticsearch (e.g. bad timestamp). A growing DLQ counter signals a problem downstream even if the sender sees no error.

Domain Controller (DC) — a server running Active Directory that manages users/computers in a domain. Here: **DC01**.

Elastic Agent — the program running on DC01 (and other systems) that collects Windows Event Logs, Sysmon data, metrics, etc. and ships them to Security Onion. Composed of multiple components, each with its own health status.

Elastic Defend (a.k.a. "Endpoint") — Elastic Agent's endpoint-security component (EDR-like). Uses its own dedicated Fleet connection (port 3765, hostgroup `endgame`), separate from ordinary log ingest.

Elasticsearch — the database Security Onion stores all logs/events in. Internally always UTC-timestamped regardless of the server's OS timezone setting.

Endpoint — usually: a computer monitored by Elastic Agent (e.g. DC01). Can also mean "Elastic Defend" specifically — context matters.

Firewall hostgroup / portgroup — see [§5.4](#). Hostgroup = named group of IPs; portgroup = named group of ports; Security Onion's firewall links the two to decide who can reach what.

Fleet — the Kibana/Elastic component for centrally managing and monitoring all Elastic Agents. Agent states: `online`, `degraded`, `offline`, `unhealthy`.

Fleet Server — the server side of Fleet, where agents check in. Runs on Security Onion, port 8220.

Hunt — Security Onion's own log/event search interface (similar to Kibana Discover, with SO's own UI wrapped around it). Left-hand menu in the SO web interface.

KVM / QEMU / libvirt — the virtualization stack running every VM in this lab. KVM = kernel technology, QEMU = hardware emulation, libvirt = the management layer (e.g. the `virsh` command).

NTP (Network Time Protocol) — protocol for syncing a computer's clock to a trusted network time source. DC01 uses `pool.ntp.org`.

PDC Emulator — an Active Directory role: the "Primary Domain Controller Emulator" is normally the authoritative time source for the whole domain. DC01 holds this role (the lab's only DC), which explains why it behaves differently from an ordinary NTP client.

Security Onion — the platform used as this lab's SOC. Bundles Suricata, Zeek, Elasticsearch, Kibana, and Fleet. Runs on VM `SOC-SecurityOnion` (192.168.50.30).

SIEM — Security Information and Event Management: collects, combines, and makes logs searchable across sources to find security incidents. Security Onion is this lab's SIEM.

Sigma rule — a general-purpose log detection rule format (analogous to Suricata rules for network traffic), describing what pattern is suspicious.

so-firewall — the CLI tool for managing Security Onion's own firewall (adding/removing hostgroup membership, applying changes). See [§5.4](#).

Sysmon (System Monitor) — a free Microsoft Sysinternals tool logging detailed Windows events (process starts, network connections, file creation, DNS queries, and more) far beyond the standard Windows Event Log. Installed on DC01 on 2026-07-13 with the SwiftOnSecurity config.

UTC (Coordinated Universal Time) — the global time standard with no timezone offset. Elasticsearch always stores timestamps in UTC internally. Dutch time (CEST in summer) is UTC+2.

vmctimesync — a Windows service that syncs the system clock with the hypervisor (originally for Hyper-V, but also active under QEMU/KVM when it exposes similar synthetic-time devices). On DC01, this service reset the clock incorrectly at every reboot even after NTP was correctly configured — disabled 2026-07-13.

Zeek (formerly Bro) — a network analysis tool that records *what* happens on the network (DNS traffic, HTTP requests, TLS certificates, connections), as opposed to Suricata which focuses on detecting known attack patterns. Part of Security Onion.

11. Current project status / what's next

As of 2026-07-13. Full detail and how to keep this current: `docs/PROJECT_STATUS.md`.

✓ Done (working, tested, documented)

- Base infrastructure: OPNsense, DC01, Security Onion, Kali, WIN11-01, ubuntu-server-01, Metasploitable2 — all running on `pentest-lab` (192.168.50.0/24).
- Event-driven traffic mirroring to Security Onion (no polling/timer), survives VM restarts.
- Active Directory operational (DC01, domain `pentest.lab`).
- Security Onion operational: web UI, Kibana, Fleet, Hunt.
- DC01 **Healthy** in Fleet with working Windows Event Log, Sysmon, and Elastic Defend telemetry — confirmed to survive an Elastic Agent restart, two DC01 reboots, and a Security Onion reboot.
- Passwordless SSH to security-onion, kali, and dc01 (confirmed 2026-07-13).
- Four working desktop launchers (start/stop lab, SSH to all machines, VM manager, Security Onion browser operator).
- Read-only web-audit script (`scripts/soc-web-audit.sh`) reporting Fleet status, data streams, and Grid status.
- The documentation structure this file is compiled from.
- **(2026-07-13, this pass)** Live network/asset verification: every VM's real IP confirmed via `virsh /ARP` (fixing a second, previously-undocumented IP error on `ubuntu-server-01`), host hardware specs confirmed, and the AD OU/group/user structure discovered to already be built (not just "planned" as the docs said).

⚠ Not yet done / open

- **opnsense SSH is not passwordless** — regression or never-actually-working; documented as working in `docs/PROJECT_STATUS.md` but denied access 2026-07-13.
- **ubuntu-server-01 SSH key login doesn't work** — needs a password or key re-deployment before its exact OS/role can be fully confirmed by login (HTTP-level role — Juice Shop — is already confirmed without login).
- DHCP ranges and DNS forwarders not documented in detail (blocked on the OPNsense SSH item).
- Security Onion's own OS-level timezone still UTC (cosmetic only — the web UI already shows Dutch time); requires broader root access than the current narrow `so-firewall sudo` scope.
- AD structural gaps: `Helpdesk` group has no members despite `Helpdesk 01` existing; `IT Admin 01` isn't actually a Domain Admin; `Employee/Manager/HR/Finance 01` have no differentiating group membership yet; `OU=Workstations / OU=Servers` are empty (WIN11-01 not moved in).
Decided 2026-07-13: these will be deliberately fixed as part of building the AD attack-escalation path — see [§12](#) — not left as-is.
- The Tier 1–3 attack-scope test pass itself, the AD escalation-path build, and the WIN11-01 cleanup/loosening are all **scoped and agreed** ([§12](#)) but deliberately **not yet executed** — queued

for a dedicated session. Pre-change snapshots (`DC01 : 2026-07-13-pre-ad-escalation-path` , `WIN11-01 : 2026-07-13-pre-target-cleanup`) are already in place for that session.

✗ Planned (from the original Fortress Bazzite design, largely still relevant)

- **Detection engineering:** most network/host detections are ⚠ "should work, not yet deliberately confirmed" — see §6.1.
- **Dashboard:** the original plan wanted host health (CPU/GPU/RAM/temps), virtualization status, security metrics (open alerts, top source/destination IPs, portscan detections), and even gaming metrics (latency, packet loss) in one view. Security Onion's own dashboards cover the security half; a combined host/gaming dashboard is not built.
- **Alert levels:** four planned tiers (INFO/WARNING/HIGH/CRITICAL) with automatic HIGH/CRITICAL forwarding to Discord/Telegram — not implemented.
- **Other:** VLAN segmentation, a separate management network and a separate attack network, additional Windows clients, honeypots, periodic Purple Team validation exercises (attack yourself, confirm Security Onion sees it).

Keeping this document (and the project) current

On every important change: 1) update the relevant specific document (troubleshooting/guide/network/server doc), 2) update `CHANGELOG.md` , 3) update `docs/PROJECT_STATUS.md` , 4) write a daily report in `docs/daily/YYYY-MM-DD/` , 5) **update this master document** so it doesn't drift from the sources it was compiled from.

12. Attack scope proposals (Red Team test plan)

Status: scope agreed with Joost on 2026-07-13, execution deliberately deferred to a later session. These scenarios are grounded in the actual, live-verified lab state above (not generic examples). The decisions below fix *what* will be tested and in *what order* — none of it has been run yet.

Agreed scope (decided 2026-07-13)

1. **Execution order: Tier 1 + Tier 2 together, first.** Recon/enumeration and exploitation of the intentionally-vulnerable targets (Metasploitable2, Juice Shop) run as one combined pass — both are low-risk since these boxes exist to be broken.
2. **Tier 3 (AD attack chain): Option B — build a deliberate privilege-escalation path before attacking it.** The environment currently has no real escalation path (`IT Admin 01` isn't a Domain Admin). Before any Kerberoasting/privilege-escalation practice, a small, deliberate AD-configuration change is needed first: set an SPN on `SQL Service` (to make Kerberoasting meaningful), and give `IT Admin 01` real elevated rights consistent with its name/OU placement. This is an infrastructure change and follows the standard procedure ([§4](#)) — explained, snapshotted, then executed as its own task, not bundled into the attack itself.
3. **WIN11-01: becomes a target too, after cleanup.** Rather than leaving it as a locked-down baseline indefinitely, WIN11-01 will be tidied up first (its computer object moved from the default `Computers` container into the already-existing `OU=Workstations`, and its configuration generally straightened out) and only then have its firewall deliberately loosened to support lateral-movement scenarios (WIN11-01 → DC01). Cleanup precedes exploitability, on purpose.

Preparation already done (2026-07-13), ahead of any of the above: fresh VM snapshots taken as the "known-good, roll back to here" point before any AD or firewall changes — `DC01` → `2026-07-13-pre-ad-escalation-path`, `WIN11-01` → `2026-07-13-pre-target-cleanup`. A first recon pass (`nmap -sn` subnet sweep from Kali) was also run and only re-confirmed the IPs already established above; a full-port scan against Metasploitable2 was started and deliberately stopped mid-run at Joost's request — **no exploitation, AD changes, or firewall changes have been executed**. All of it — recon, exploitation, the AD escalation-path build, and the WIN11-01 cleanup/loosening — is scoped and queued for a dedicated session, not folded into documentation work.

Every scenario below is scoped to stay **entirely inside** `192.168.50.0/24`, launched from `ATTACK-Kali` (192.168.50.50), against only the lab's own intentionally-vulnerable or lab-owned systems. Nothing here should ever leave that boundary.

Tier 1 — Reconnaissance & enumeration (lowest risk, good first step)

Goal: exercise Security Onion's network-detection coverage ([§6.1](#)) and turn its ⚠️ ("should detect, not confirmed") rows into ✅.

Scenario	Target	Technique	What it should trigger in Security Onion
Full port/service scan	Target-Metasploitable2 (.70)	<code>nmap -sV -sC -p-</code> from Kali	TCP SYN scan detection (Suricata), connection-log volume spike (Zeek)
Web app recon	ubuntu-server-01:3000 (Juice Shop)	<code>nikto</code> , <code>gobuster</code> / <code>ffuf</code> directory brute-force	HTTP scanning/brute-force signatures
AD/domain enumeration	DC01 (.10)	<code>enum4linux-ng</code> , <code>crackmapexec smb</code> , anonymous LDAP bind attempts	SMB enumeration signatures, possibly anomalous LDAP traffic
Network sweep	Whole .0/24	<code>nmap -sn</code>	ICMP sweep detection

Tier 2 — Exploitation of intentionally-vulnerable targets (low risk — these boxes exist to be broken)

Scenario	Target	Technique	Detection goal
vsftpd backdoor	Metasploitable2:21	<code>vsftpd_234_backdoor</code> Metasploit module (already done once historically per §8 — good repeat/regression test)	Exploit-signature + reverse-shell detection (network + would-be host telemetry if this were a monitored host)
Samba/NFS/RMI exploitation	Metasploitable2	<code>usermap_script</code> , NFS anonymous mount, Java-RMI deserialization	Exploit signatures, anomalous file-share/RPC activity
OWASP Top 10 walkthrough	Juice Shop (ubuntu-server-01:3000)	SQLi, broken auth, IDOR, XSS — Juice Shop has built-in scored challenges that map directly to these	Web-attack rulesets (SQLi/XSS/traversal), abnormal HTTP patterns
UnrealIRCd backdoor	Metasploitable2:6667	Known backdoor trigger	Exploit signature

Tier 3 — Active Directory attack chain (needs a scoping decision first)

This tier is more sensitive because it touches the identity system the rest of the lab's monitoring depends on, and — per the AD gaps found in §3.3 — **the environment doesn't yet have a built-in privilege-escalation path**: `IT Admin 01` isn't actually a Domain Admin, and the role accounts (Employee/Manager/HR/Finance 01) are undifferentiated. Two honest options, worth deciding together rather than assuming:

- **Option A — test detection on the environment as it is.** Password spraying / brute force against the real, existing accounts (`soctest` , `Helpdesk 01` , `Employee 01` , `Manager 01` , `HR 01` , `Finance 01` , `IT Admin 01`) will exercise failed-login detection, but any "compromise" of `IT Admin 01` won't actually lead anywhere, since it has no elevated rights today.

- **Option B — build a deliberate escalation path first** (e.g. actually grant `IT Admin 01` local-admin-on-WIN11-01 or a real Domain Admin path, link `Helpdesk 01` into the `Helpdesk` group with some real permission, set an SPN on `SQL Service` to make Kerberoasting meaningful), *then* attack it. This is an infrastructure change and needs the standard change procedure (explain → risk → backup → confirm → execute → document) — it's a small AD-configuration task, not a Red Team action.

Scenario	Target	Technique	Needs Option B first?
Password spraying	DC01 (.10)	Common passwords against all known usernames, low attempt-count per account to avoid lockout	No
Kerberoasting	DC01	Request a TGS for <code>SQL Service</code> , crack offline	Yes — needs an SPN set on the account first
AS-REP roasting	DC01	Only works on accounts with Kerberos pre-auth disabled	Yes — no such account exists yet
Lateral movement	WIN11-01 → DC01	From an assumed-compromised WIN11-01 foothold, attempt to reach DC01	Partially — WIN11-01's firewall currently blocks most lateral techniques (§3.4); this itself is worth testing "as-is" first (does it hold?) before deciding whether to loosen it for training purposes
Golden/Silver ticket practice	DC01	Requires prior privileged access — a capstone scenario, not a starting one	Yes

Next session checklist (execution, not documentation)

When the actual test pass happens, in the agreed order:

1. Run Tier 1 (recon) + Tier 2 (exploitation of Metasploitable2/Juice Shop) from Kali; cross-check each against Security Onion Hunt/Detections to flip the relevant 🚩 rows in §6.1 to ✅ or ❌.
2. Build the AD escalation path (SPN on `SQL Service`, elevate `IT Admin 01`) as its own explained/snapshotted/confirmed change — snapshot `2026-07-13-pre-ad-escalation-path` is already in place to roll back to.
3. Clean up WIN11-01 (move `DESKTOP-EFKB8GQ` into `OU=Workstations`, general tidy-up) — snapshot `2026-07-13-pre-target-cleanup` is already in place — then loosen its firewall deliberately for lateral-movement testing.
4. Run the Tier 3 AD attack chain against the now-real escalation path, and the WIN11-01 → DC01 lateral-movement scenario.
5. Update this document (§6.1 status table, §11 status) with what was actually confirmed.

Document index (sources compiled into this file)

Root: README.md , LAB_OVERVIEW.md , PROJECT_RULES.md , AI_ACCESS_POLICY.md , NETWORK.md , SERVERS.md , SECURITY.md , ACTIVE_DIRECTORY.md , CHANGELOG.md . docs/ : INDEX.md , ASSET_INVENTORY.md , GLOSSARY.md , PROJECT_STATUS.md , decisions/*.md , guides/*.md (11 files), troubleshooting/01 – 06 , chat_history/*.md (6 files), daily/*/ (2026-07-03 through 2026-07-13).

Note: pentest.lab - by Joost Hebly.md (repo root) is an earlier, unmerged concatenation of the same source files, generated for the portfolio deliverable — this document supersedes it as the synthesized reference; that file remains useful as the literal, unedited per-file archive.